

IF966- Introdução aos Sistemas de Informação

Kiev Gama
kiev@cin.ufpe.br

NOTÍCIAS

SEGURANÇA E PRIVACIDADE

Após negar ataque, TSE tem bancos de dados expostos por hackers em dia de eleição

Renato Santino | 15 de novembro de 2020

[Início](#) » [Antivírus e Segurança](#) » Exclusivo: vazamento que expôs 220 milhões de brasileiros é pior do que se pensava

Exclusivo: vazamento que expôs 220 milhões de brasileiros é pior do que se pensava

Vazamento inclui CPF, foto de rosto, endereço, telefone, e-mail, score de crédito, salário e mais; Serasa nega ser fonte dos dados



Por [Felipe Ventura](#)
22/01/2021 às 14:10

NEWS

Americanas teve prejuízo de R\$ 923 milhões com ataques cibernéticos

16/05/2022 às 17:08 • 1 min de leitura

COMPARTILHE

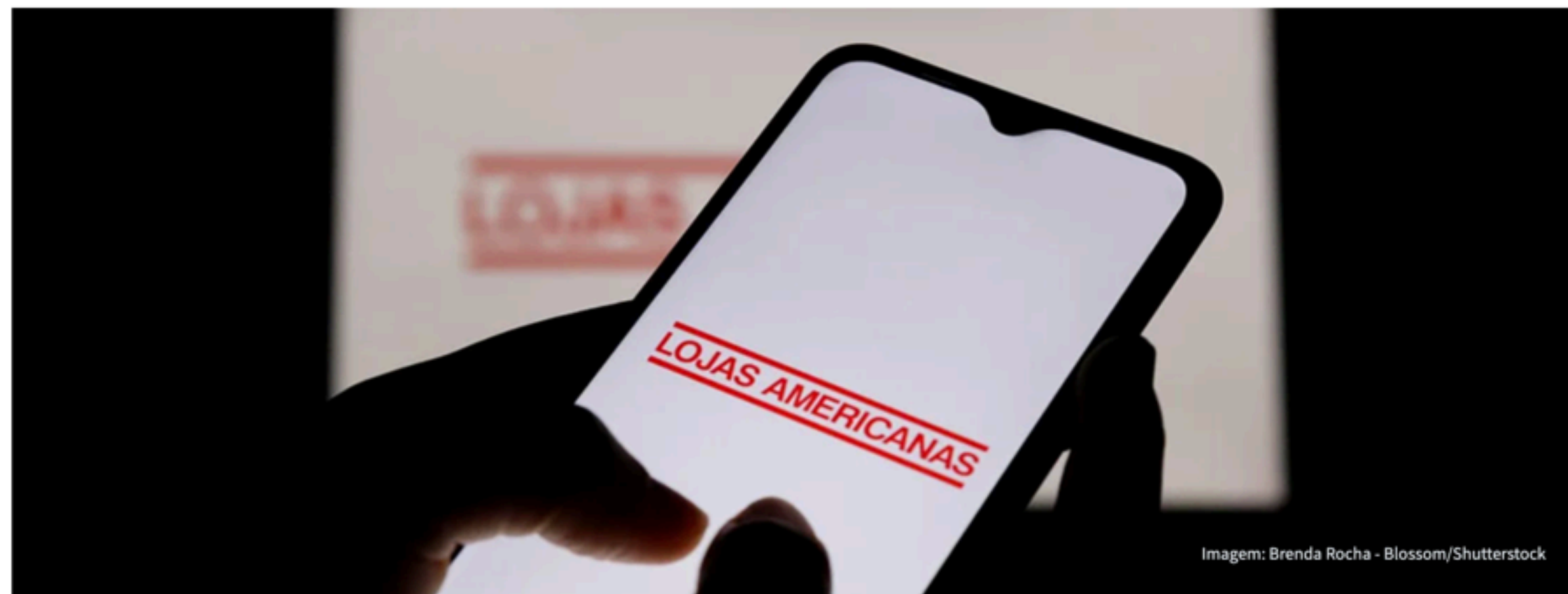


Imagem: Brenda Rocha - Blossom/Shutterstock



[Início](#) > [Newsletter \(TI Inside\)](#) > [Brasil sofreu mais de 33 milhões de tentativas de ransomware em 2021](#)

CIBERSEGURANÇA

Brasil sofreu mais de 33 milhões de tentativas de ransomware em 2021

Por [Redação](#) - 18 de fevereiro de 2022



7 DAY SALE 6 Months For \$15

SALE ENDS
JAN 27TH

SUBSCRIBE NOW

LAST
CHANCE



TIME

TIME 2030

JOE BIDEN'S FIRST 100 DAYS

VIDEO



NEWSLETTER

SUBSCRIBE



TECH • SECURITY

U.S. Nuclear Weapons Agency Hacked as Part of Massive Cyber-Attack

BY **WILLIAM TURTON, MICHAEL RILEY AND JENNIFER JACOBS / BLOOMBERG**

DECEMBER 17, 2020 11:07 PM EST

‘Ultimate’ MiTM Attack Steals \$1M from Israeli Startup

[VIDEOS](#)[WINDOWS 10](#)[5G](#)[BEST VPNs](#)[CLOUD](#)[SECURITY](#)[AI](#)[MORE ▼](#)[NEWSLETTERS](#)[ALL WRITERS](#)

MUST READ: [The developer's dream? This company's tech workspace brings Agile development to life](#)

GitHub hit with the largest DDoS attack ever seen

DDoS attackers have found a new way of magnifying their attacks, with experts warning that bigger attacks are likely.

<https://www.zdnet.com/article/github-was-hit-with-the-largest-ddos-attack-ever-seen/>



Facebook <c34327907@e-e.com>

Wed 1/30/2019 6:57 AM

To: You

facebook

Cher(e) Client (e),

Par mesures de sécurité et par notre expérience, nous contrôlons tous les charges inhabituelles lies à votre compte. Nous avons le regret de vous informer que votre compte Facebook sera limite, à cause d'un mouvement inhabituel sur votre compte.

Pour supprimer cette limitation veuillez mettre à jour de votre information personnelle concernant votre compte.

Vous avez un délai de 48h pour rétablir l'accès à votre compte.

Mettre à jour vos informations personnelles

Merci

Facebook, Inc., Attention: Department 415, PO Box 10005, Palo Alto, CA 94303

EMPRESA

50 mil empresas estão expostas a hackers por falha em softwares da SAP, dizem pesquisadores

A gigante de software alemã SAP divulgou orientações sobre como configurar corretamente os ajustes de segurança em 2009 e 2013

🕒 1 min de leitura

REUTERS

REUTERS

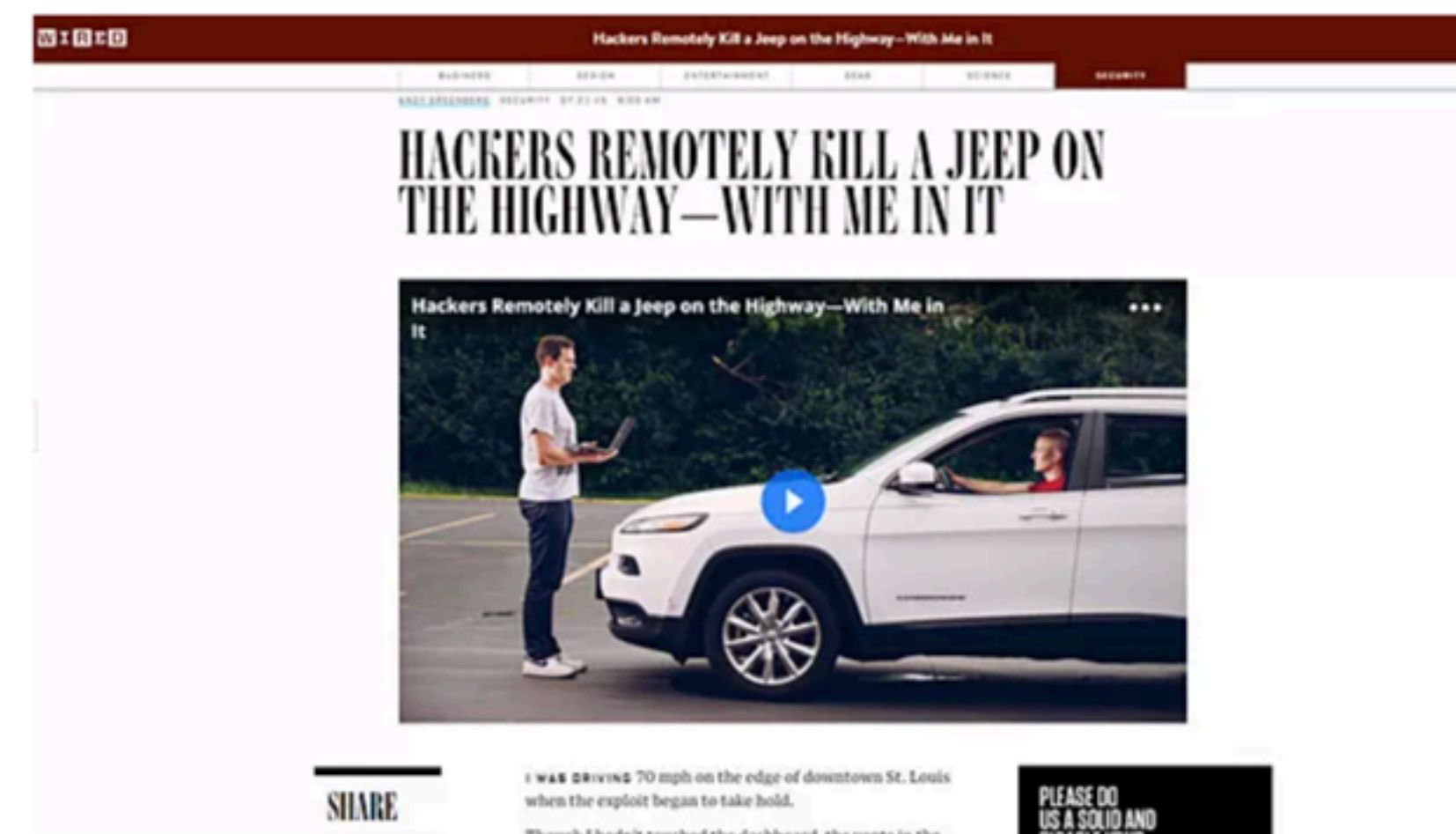
02 MAI 2019 - 15H23 | ATUALIZADO EM 02 MAI 2019 - 15H23

22/07/2015 11h58 - Atualizado em 22/07/2015 14h36

De longe, hackers 'invadem' e controlam carro com jornalista dentro

Hackers usam brecha no sistema de entretenimento de um Cherokee. Chrysler do Brasil informa que esse sistema não é igual ao vendido no país.

Do G1, em São Paulo



Hackers usaram um Jeep Cherokee 2014, mas outros modelos também estão suscetíveis (Foto: Reprodução/Wired)

segurança da informação

segurança da informação

refere-se a todos os processos e políticas projetadas para proteger a informação e os sistemas de informação (SI) de uma organização contra acesso não autorizado, uso, divulgação, interrupção, modificação ou destruição.

RAINER, R. Kelly; PRINCE, Brad. Introduction to information systems. John Wiley & Sons, 2014. 5th edition, Wiley & Sons.

sistemas de computação seguros

Necessidade de **modelos sólidos** para construir tais sistemas

Definir **propriedades de segurança**

Antecipar **tipos de ataques**

Testar implementação do hardware e software

Monitorar comportamento do sistema

Correções aplicadas assim que disponíveis

c.i.a.

"tríade da segurança da informação"

confidentiality

integrity

availability (disponibilidad)

confidentiality

Confidencialidade é evitar a divulgação não autorizada de informações.

a confidencialidade envolve a proteção de dados, fornecendo acesso para aqueles que têm permissão para vê-los, ao mesmo tempo em que impede que outros saibam qualquer coisa sobre seu conteúdo.

i integrity

Integridade: a propriedade de que as informações não sejam alteradas de forma não autorizada.

aavailability

Disponibilidade: a propriedade de que a informação é acessível e modificável em tempo hábil por aqueles autorizados a fazê-lo.

vulnerabilidades podem permitir
ataques e vazamento de informação

ameaças e vulnerabilidades

Ativo (Asset) - Pessoas, propriedades, informações, sistemas.

Uma **ameaça** (threat) a um é qualquer perigo ao qual um ativo possa estar exposto.

Vulnerabilidade é a possibilidade de que um ativo seja prejudicado por uma ameaça.

Fatores contribuindo para o aumento de vulnerabilidades

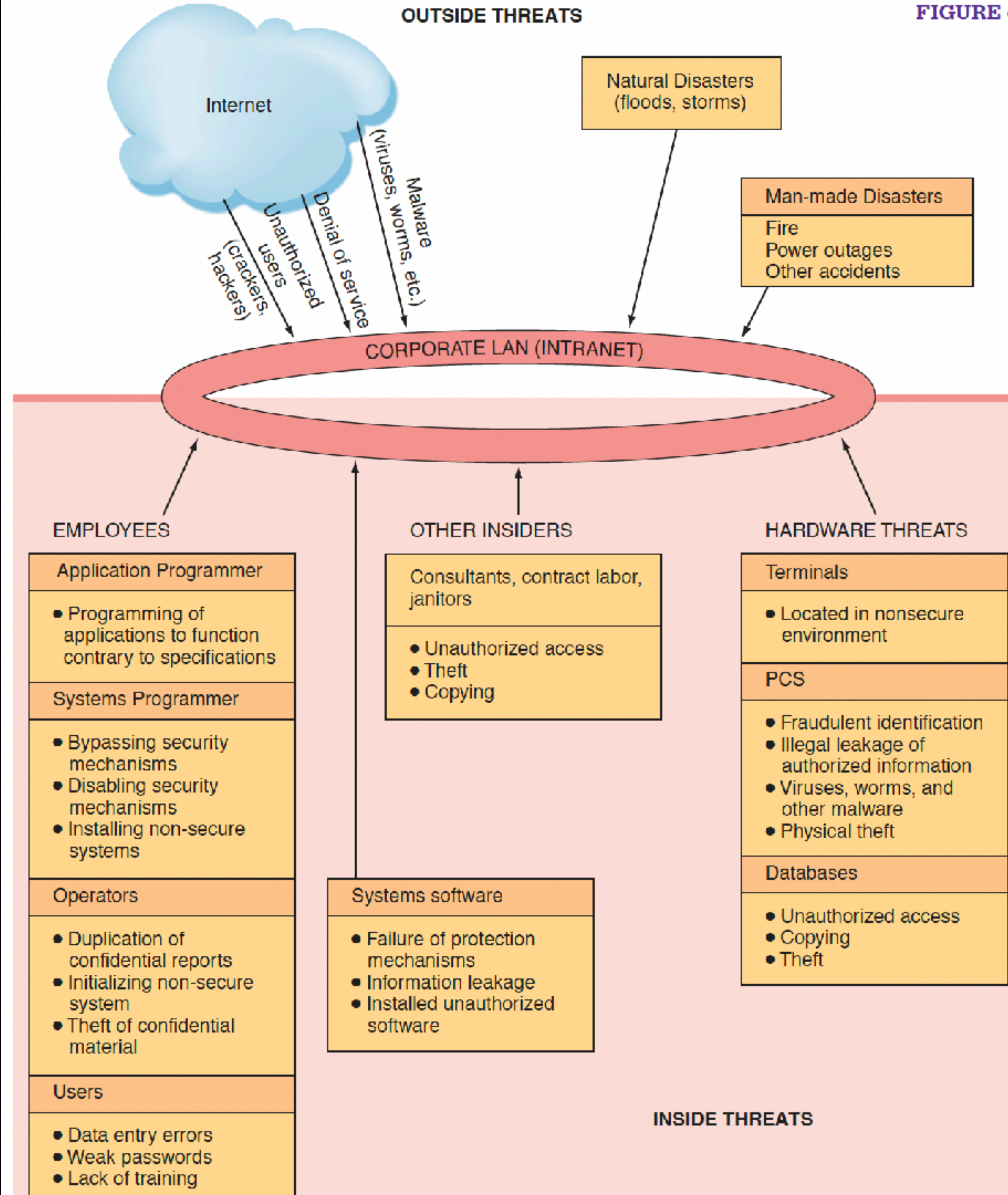
Ambiente de negócios interconectado, interdependente e sem fio de hoje;

Computadores e dispositivos de armazenamento menores, mais rápidos e mais baratos;

Diminuíram-se as habilidades necessárias para ser um hacker de computador;

Crime organizado internacional assumindo cibercrimes;

Falta de apoio da gestão.



Ameaças não intencionais

Erro humano

Descuidos com dispositivos

Abrir emails de procedência duvidosa

Navegar pela Internet de forma descuidada

Senhas fracas e mal protegidas

Descuidos com o ambiente físico de trabalho

Descuidos com descarte de equipamentos

Engenharia social

enganar ou manipular funcionários legítimos para que forneçam informações confidenciais da empresa (ex: senhas)

Privacidade importa

Como proteger seus dados ao descartar equipamentos eletrônicos?

Conheça os cuidados necessários ao se desfazer de máquinas e dispositivos que podem possuir informações pessoais como nome completo, CPF, endereço, fotos e outros



Ameaças intencionais

Espionagem ou invasão

Extorsão de informação e ransomware

Sabotagem ou vandalismo

Roubo de equipamentos ou informações, "dumpster diving"

Roubo de identidade

Compromissos com a propriedade intelectual

Ataques de controle de supervisão e aquisição de dados (SCADA)

Ciberterrorismo e guerra cibernética

“Alien Software” (Adwares, Spywares, Keyloggers, Cookies)

Ataques de software malicioso (malware)

**software malicioso
(malware)**

Malware

Insider Attacks

- Backdoor

- Logic bomb

Malware can be also be classified into categories, depending on propagation and concealment

Propagation

- Virus: human-assisted propagation (e.g., open email attachment)

- Worm: automatic propagation without human assistance

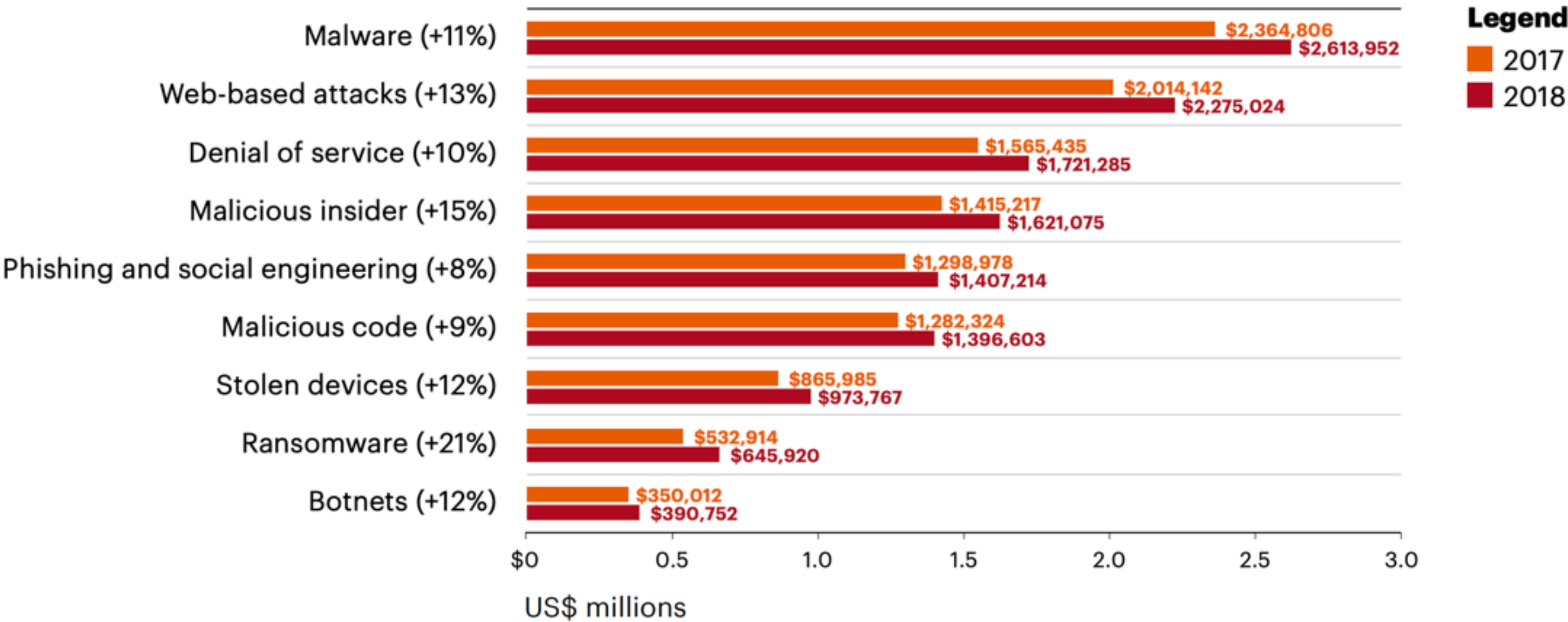
Concealment

- Rootkit: modifies operating system to hide its existence

- Trojan: provides desirable functionality but hides malicious operation

Malware is the most expensive attack type for organizations. The cost of malware attacks has increased by 11% over the year, and the cost of malicious insider attacks has increased by 15%.

FIGURE 6
Average annual cost of cybercrime by type of attack
(2018 total = US\$13.0 million)



Insider Attacks

An **insider attack** is a security breach that is caused or facilitated by someone who is a part of the very organization that controls or builds the asset that should be protected.

These are installed to allow easy access to a running program for debugging purposes.

In the case of malware, an insider attack refers to a security hole that is created in a software system by one of its programmers.

Insider Attacks

Back Door

Logic Bomb

Back door

Hidden feature or command that lets a user perform actions that normally would not be allowed.

Backdoors typically involve mechanisms for bypassing authentication



US SECURITY AGENCY DOES NOT DENY STILL USING SECRET BACKDOORS IN TECH DEVICES

The agency has 'stonewalled' on providing any information on new guidelines following Snowden scandal

Adam Smith | @adamndsmith | Thursday 29 October 2020 15:21 | comments



Logic Bombs

A **logic bomb** is a program that performs a malicious action as a result of a certain logic condition.

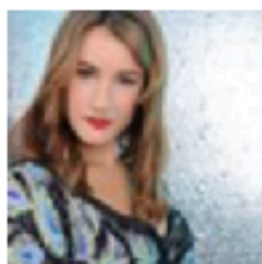
Programing errors don't count.

A malicious purpose needs to motivate the change that causes trouble.

Often the motive is one of extortion.

18 DEC 2019 NEWS

Siemens Contractor Jailed for Planting Logic Bombs



Sarah Coble News Writer



A Siemens contractor who sabotaged computer programs so that he would later be re-hired to fix them has been jailed.



David Tinley of Harrison City, Pennsylvania, pleaded **guilty** in federal court to a charge of intentional damage to a protected computer back in July 2019.



Between 2014 and 2016, the 62-year-old computer programmer inserted malicious pieces of code known as logic bombs into software used at the Monroeville branch of Siemens in Pennsylvania. The logic bombs were designed to unleash code that would cause the software to malfunction after specific circumstances arose.

"The logic bombs ensured that the programs would malfunction after the expiration of a certain date. As a result, Siemens was unaware of the cause of the malfunction and required Tinley to fix these malfunctions," reads a statement released July 19, 2019, by the United States Attorney's Office of the western district of Pennsylvania.



Related to This Story

Computer Viruses

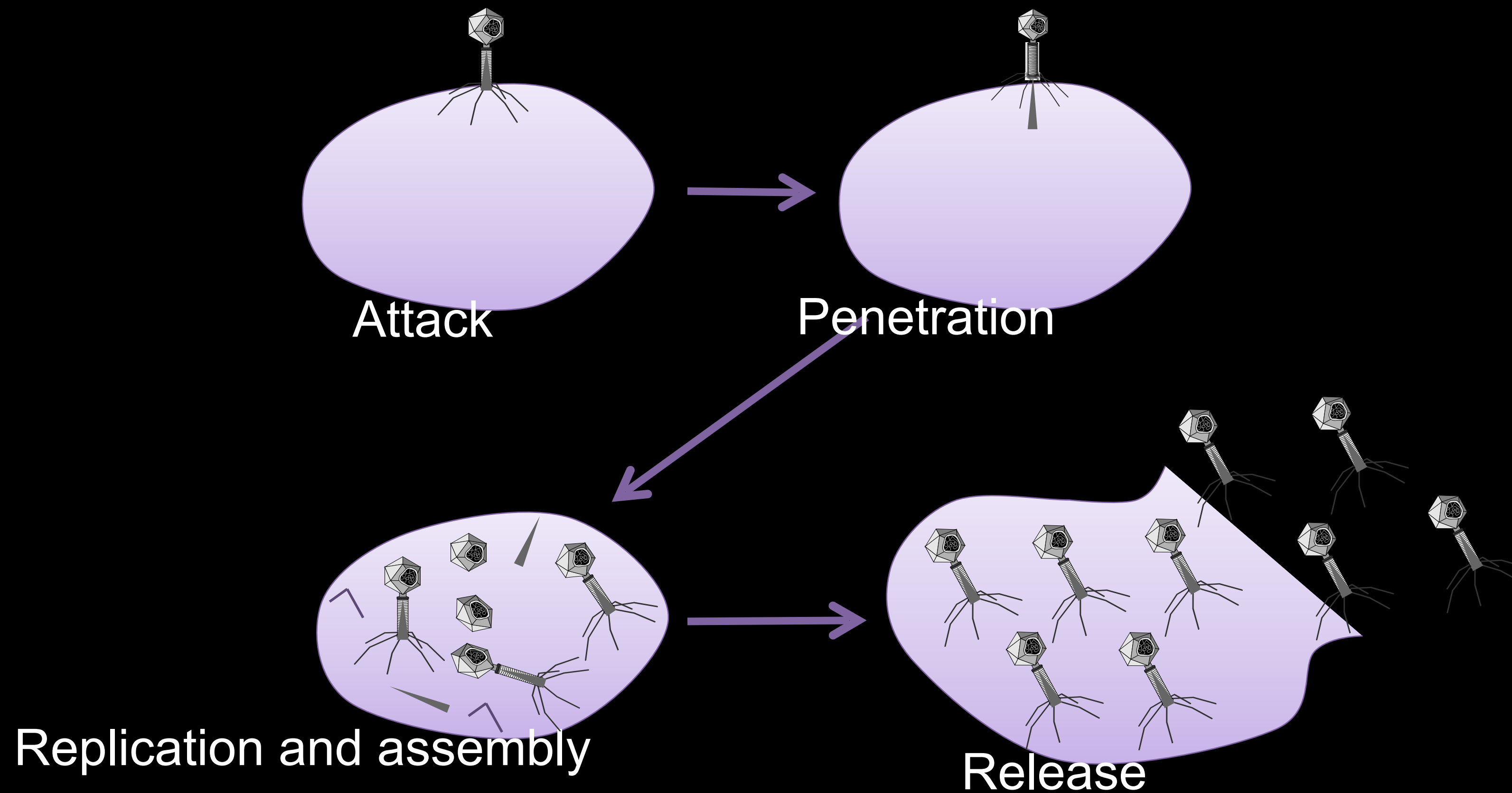
A **computer** virus is computer code that can replicate itself by modifying other files or programs to insert code that is capable of further replication.

This self-replication property is what distinguishes computer viruses from other kinds of malware, such as logic bombs.

Another distinguishing property of a virus is that replication requires some type of user assistance, such as clicking on an email attachment or sharing a USB drive.

Biological Analogy

Computer viruses share some properties with biological viruses



Virus Phases

Dormant phase.

During this phase, the virus just exists—the virus is laying low and avoiding detection.

Propagation phase.

During this phase, the virus is replicating itself, infecting new files on new systems.

Triggering phase.

In this phase, some logical condition causes the virus to move from a dormant or propagation phase to perform its intended action.

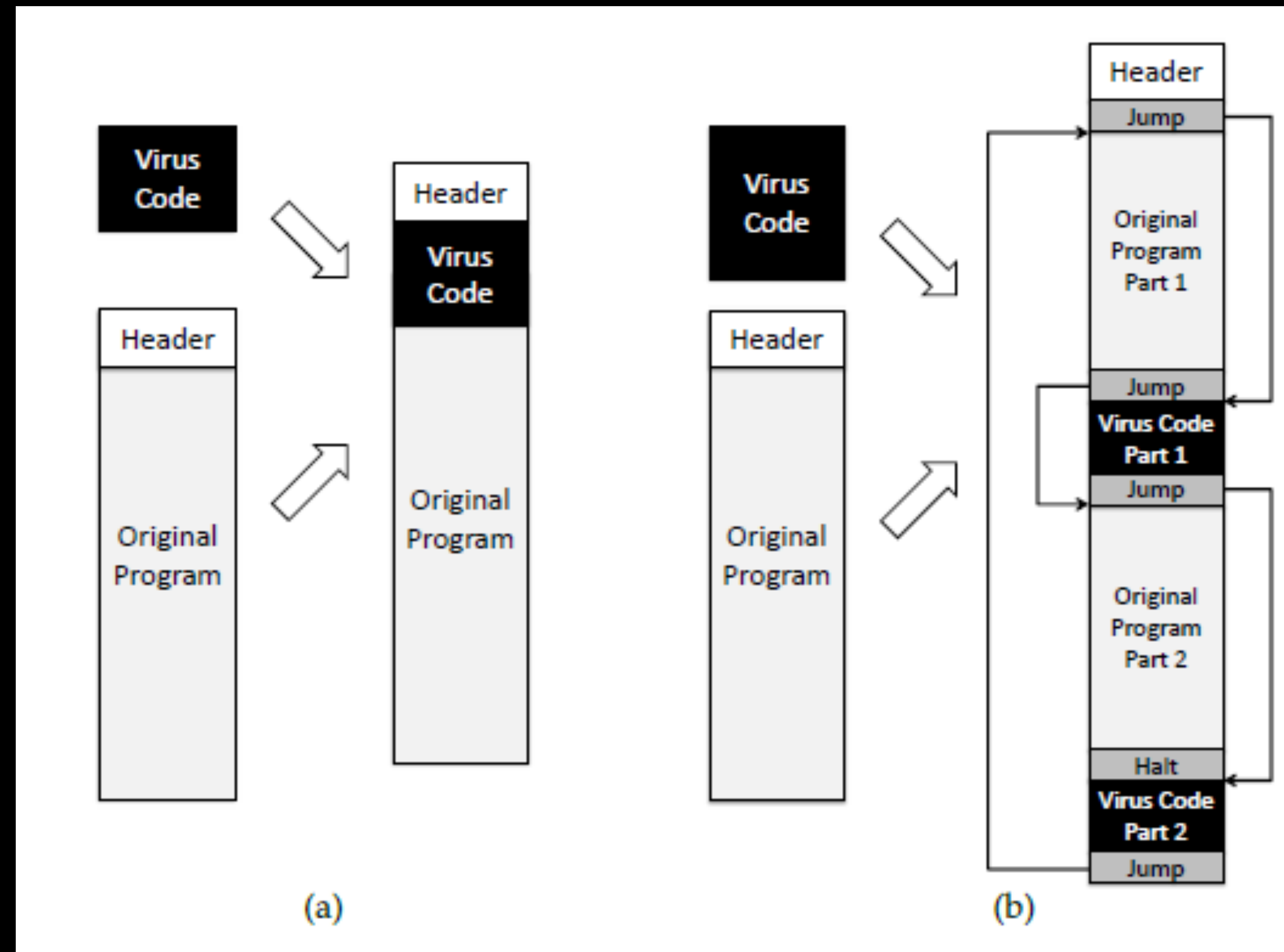
Action phase.

In this phase, the virus performs the malicious action that it was designed to perform, called **payload**.

This action could include something seemingly innocent, like displaying a silly picture on a computer's screen, or something quite malicious, such as deleting all essential files on the hard drive.

Degrees of Complication

Viruses have various degrees of complication in how they can insert themselves in computer code.



Computer Worms

A **computer worm** is a malware program that spreads copies of itself without the need to inject itself in other programs, and usually without human interaction.

They are technically not computer viruses (since they don't infect other programs), but some people nevertheless confuse the terms, since both spread by self-replication.

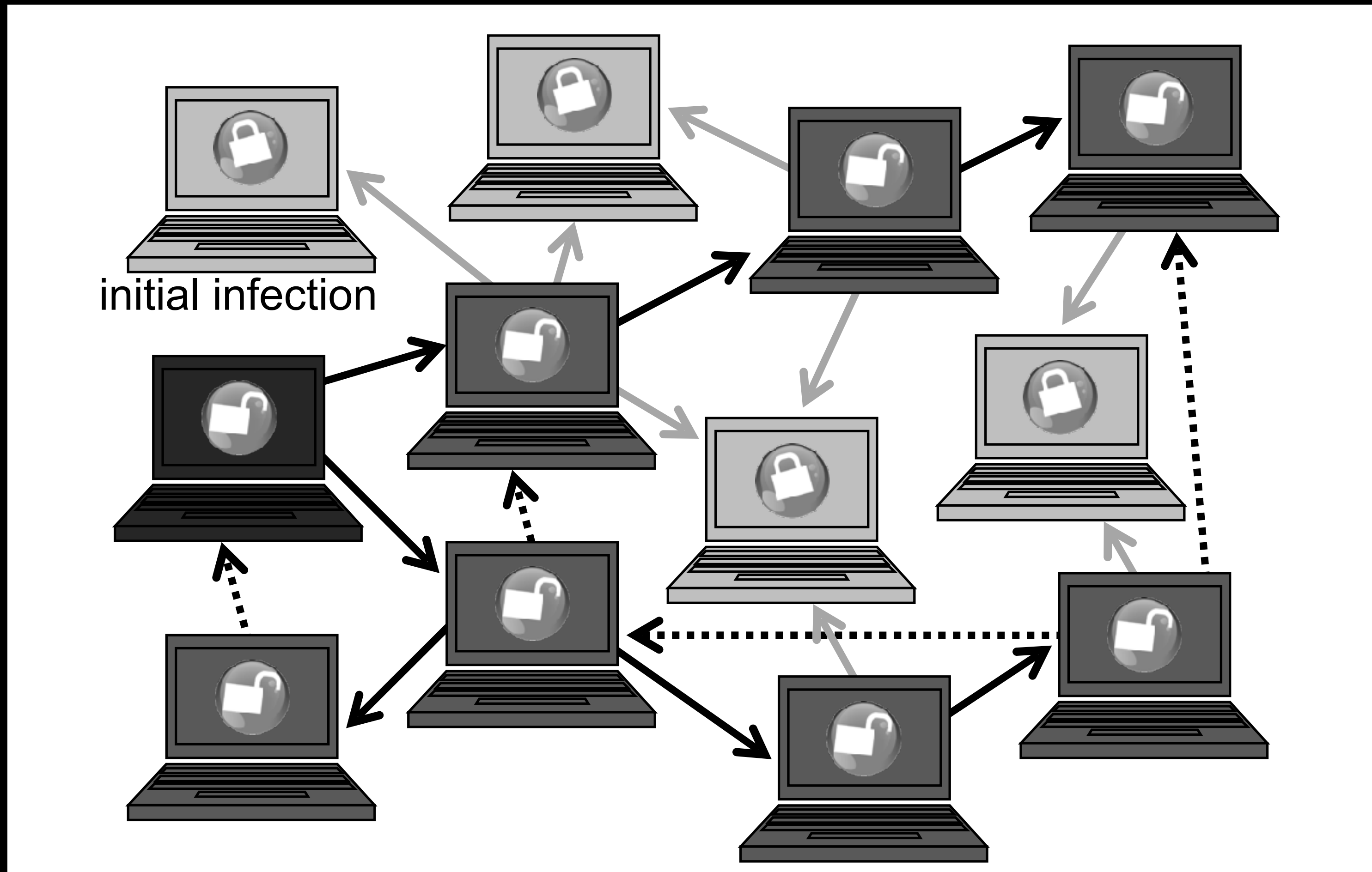
In most cases, a computer worm will carry a malicious payload, such as deleting files or installing a backdoor.

Worm Propagation

Worms propagate by finding and infecting vulnerable hosts.

They need a way to tell if a host is vulnerable

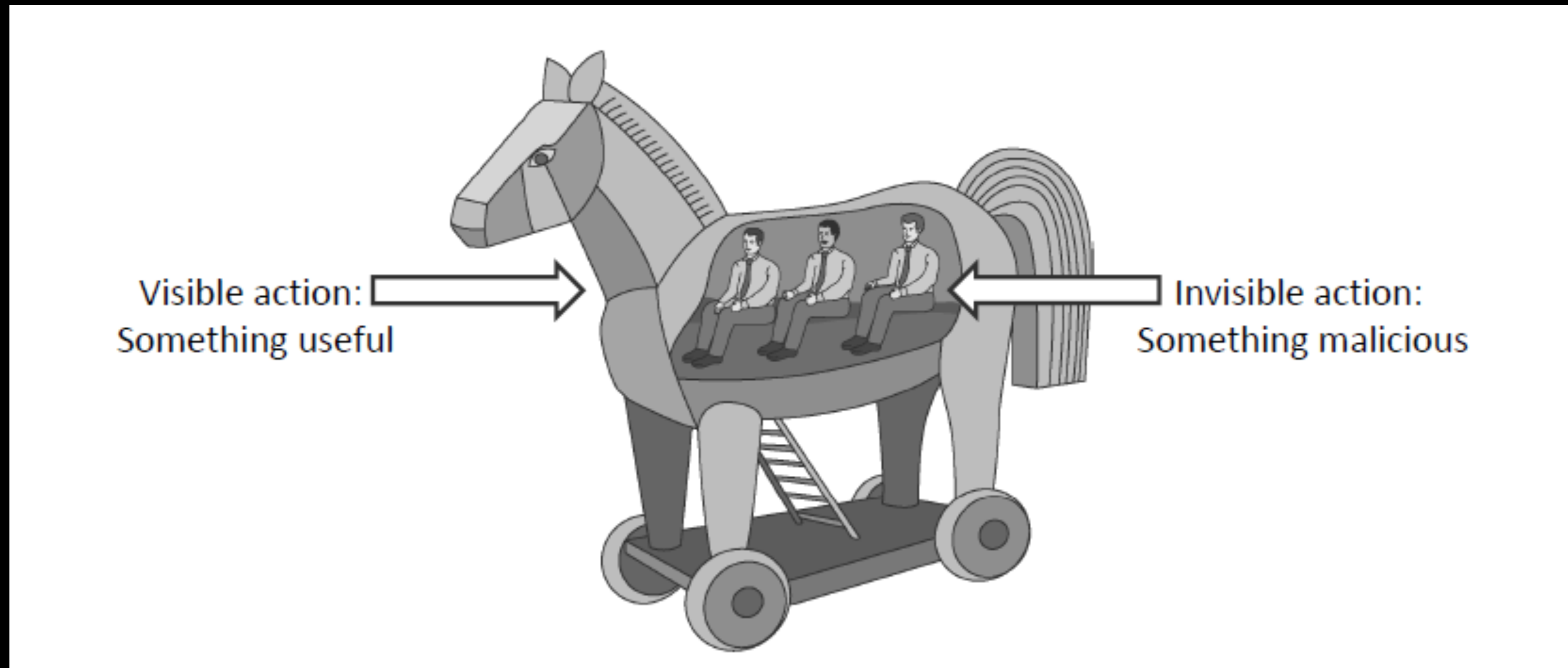
They need a way to tell if a host is already infected.

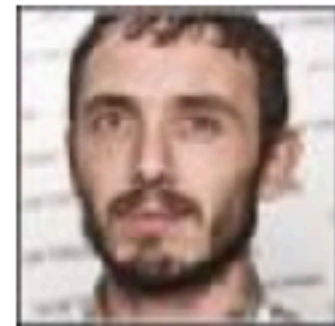


Trojan Horses

A **Trojan horse (or Trojan)** is a malware program that appears to perform some useful task, but which also does something with negative consequences (e.g., launches a keylogger).

Trojan horses can be installed as part of the payload of other malware but are often installed by a user or administrator, either deliberately or accidentally.





'Cookiethief' Android Malware Hijacks Facebook Accounts

By [Ionut Arghire](#) on March 13, 2020



Share



Tweet



Recommend 22



RSS

A recently discovered **Android Trojan** was designed to gain root access on infected devices and hijack Facebook accounts by stealing cookies from the browser and the social media app.

EXAMPLES OF TROJAN HORSE VIRUS



Backdoor Trojans



Fraudulent antivirus Trojans



Downloader Trojans



Mailfinder Trojans



Rootkit Trojans



Remote Access Trojans

Rootkits

A **rootkit** modifies the operating system to hide its existence

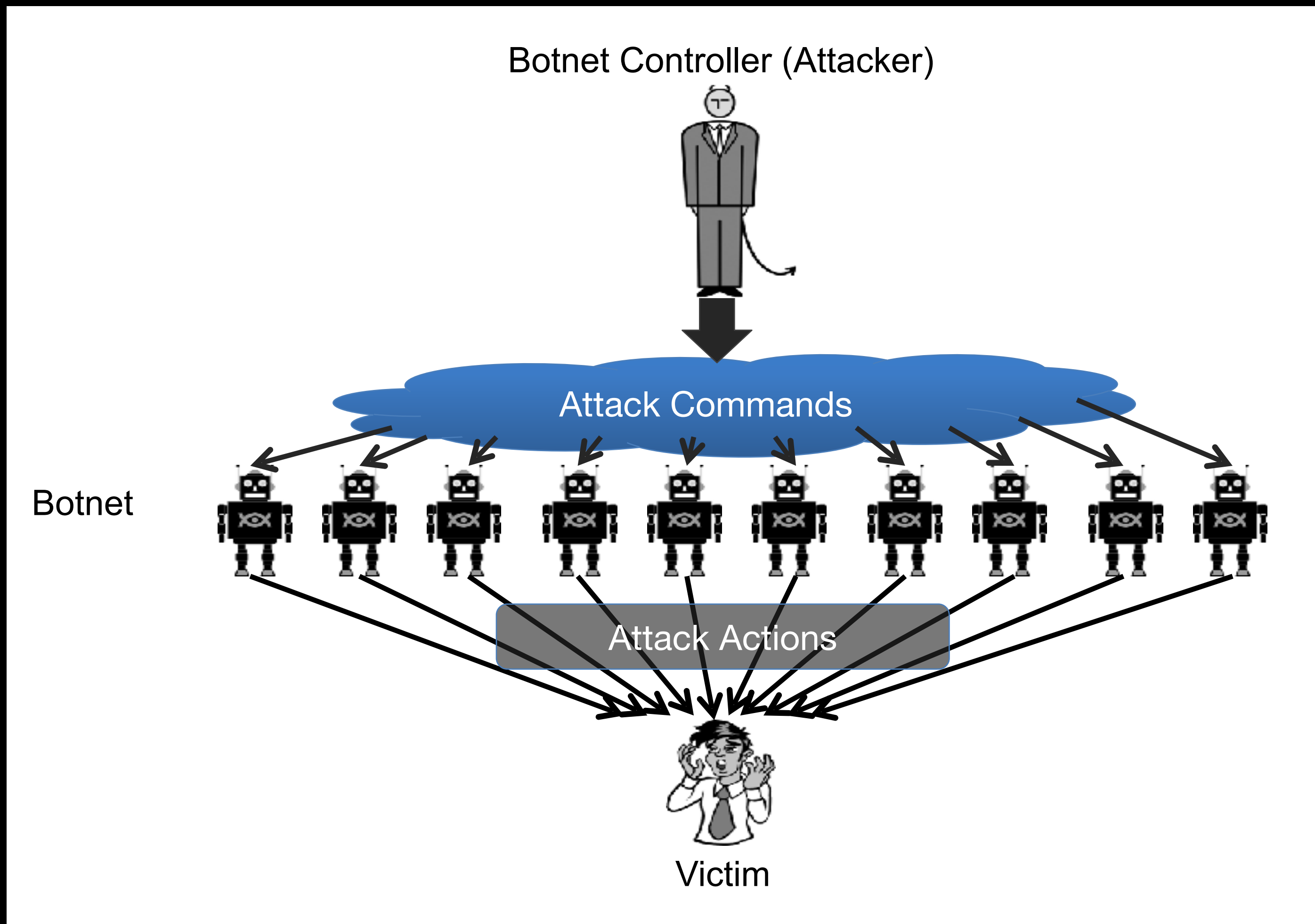
E.g., modifies file system exploration utilities

Hard to detect using software that relies on the OS itself

enable cybercriminals to steal personal data and financial information, install malware or use computers as part of a botnet to circulate spam and participate in DDoS (distributed denial of service) attacks.

Botnets

Malware can turn a computer in to a **zombie**, which is a machine that is controlled externally to perform malicious attacks, usually as a part of a botnet.



Outros tipos de Malware

Ransomware

Spyware

Adware

Phishing Malware

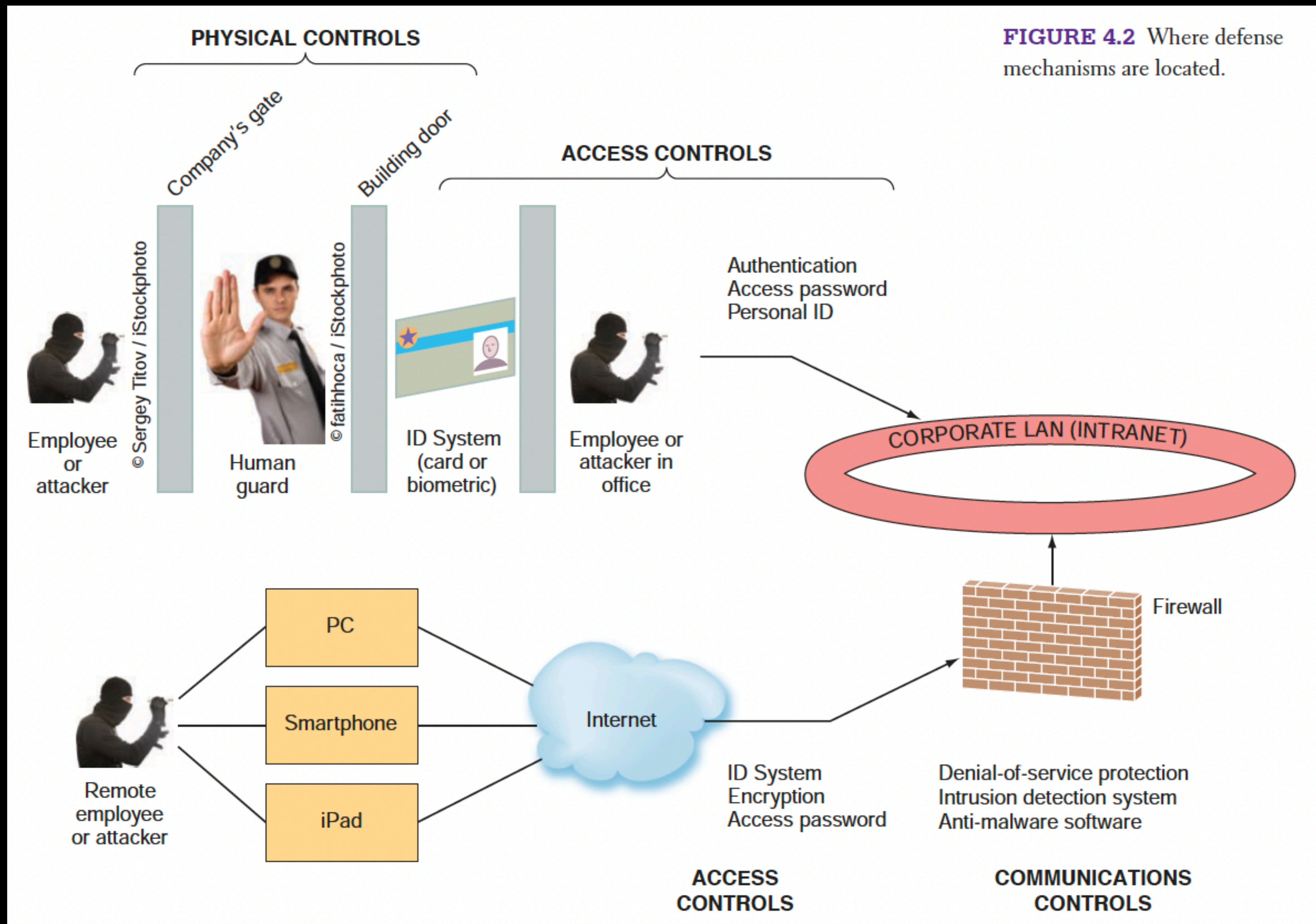
Cryptojacking

Scareware

Keyloggers

...

Mecanismos de Controle de Segurança da Informação



Material de leitura:

The 10 most common ERP security issues and ways to fix them

1. Unknown vulnerabilities
2. Missing software updates
3. Weak ERP authentication
4. Web application-specific vulnerabilities
5. Open network shares
6. Lack of issue flagging
7. Lack of incident response planning
8. Lack of proper testing
9. Unclear employee expectations
10. Lack of ongoing education for technical staff

Casos de falhas de segurança da informação (em dupla)

Buscar por case de falha de segurança em ambiente de sistemas corporativos (ERPs, CRMs, SCMs, etc).

Escrever resumo em uma página citando:

- Contexto da empresa e do problema
- Que tipo de falha foi encontrada?
- Que princípio(s) de segurança da informação foi ou foram violado(s)? Confidencialidade? Integridade? Disponibilidade?
- Que prejuízos gerou?
- É possível identificar como contornaram o problema?